

SNMP

Simple Network Management Protocol (SNMP) was created to monitor network devices. In addition, this protocol can also be used to handle configuration tasks and change settings remotely. SNMP-enabled hardware includes routers, switches, servers, IoT devices, and many other devices that can also be queried and controlled using this standard protocol. Thus, it is a protocol for monitoring and managing network devices. In addition, configuration tasks can be handled, and settings can be made remotely using this standard. The current version is **SNMPv3**, which increases the security of SNMP in particular, but also the complexity of using this protocol.

In addition to the pure exchange of information, SNMP also transmits control commands using agents over UDP port **161**. The client can set specific values in the device and change options and settings with these commands. While in classical communication, it is always the client who actively requests information from the server, SNMP also enables the use of so-called **traps** over UDP port **162**. These are data packets sent from the SNMP server to the client without being explicitly requested. If a device is configured accordingly, an SNMP trap is sent to the client once a specific event occurs on the server-side.

For the SNMP client and server to exchange the respective values, the available SNMP objects must have unique addresses known on both sides. This addressing mechanism is an absolute prerequisite for successfully transmitting data and network monitoring using SNMP.

MIB

To ensure that SNMP access works across manufacturers and with different client-server combinations, the **Management Information Base (MIB)** was created. MIB is an independent format for storing device information. A MIB is a text file in which all queryable SNMP objects of a device are listed in a standardized tree hierarchy. It contains at least one **Object Identifier (OID)**, which, in addition to the necessary unique address and a name, also provides information about the type, access rights, and a description of the respective object. MIB files are written in the **Abstract Syntax Notation One (ASN.1)** based ASCII text format. The MIBs do not contain data, but they explain where to find which information and what it looks like, which returns values for the specific OID, or which data type is used.

OID

An OID represents a node in a hierarchical namespace. A sequence of numbers uniquely identifies each node, allowing the node's position in the tree to be determined. The longer the chain, the more specific the information. Many nodes in the OID tree contain nothing except references to those below them. The OIDs consist of integers and are usually concatenated by dot notation. We can look up many MIBs for the associated OIDs in the [Object Identifier Registry](#).

SNMPv1

SNMP version 1 (**SNMPv1**) is used for network management and monitoring. SNMPv1 is the first version of the protocol and is still in use in many small networks. It supports the retrieval of information from network devices, allows for the configuration of devices, and provides traps, which are notifications of events. However, SNMPv1 has **no built-in authentication** mechanism, meaning anyone accessing the network can read and modify network data. Another main flaw of SNMPv1 is that it **does not support encryption**, meaning that all data is sent in plain text and can be easily intercepted.

SNMPv2

SNMPv2 existed in different versions. The version still exists today is **v2c**, and the extension **c** means community-based SNMP. Regarding security, SNMPv2 is on par with SNMPv1 and has been extended with additional functions from the party-based SNMP no longer in use. However, a significant problem with the initial execution of the SNMP protocol is that the **community string** that provides security is only transmitted in plain text, meaning it has no built-in encryption.

SNMPv3

The security has been increased enormously for **SNMPv3** by security features such as **authentication** using username and password and transmission **encryption** (via **pre-shared key**) of the data. However, the complexity also increases to the same extent, with significantly more configuration options than **v2c**.

Community Strings

Community strings can be seen as passwords that are used to determine whether the requested information can be viewed or not. It is important to note that many organizations are still using **SNMPv2**, as the transition to **SNMPv3** can be very complex, but the services still need to remain active. This causes many administrators a great deal of concern and creates some problems they are keen to avoid. The lack of knowledge about how the information can be obtained and how we as attackers use it makes the administrators' approach seem inexplicable. At the same time, the lack of encryption of the data sent is also a problem. Because every time the community strings are sent over the network, they can be intercepted and read.

Default Configuration

The default configuration of the SNMP daemon defines the basic settings for the service, which include the IP addresses, ports, MIB, OIDs, authentication, and community strings.

SNMP Daemon Config

SNMP Daemon Config

```
dbcyp0n@htb[/htb]$ cat /etc/snmp/snmpd.conf | grep -v "#" | sed -r '/^\s*$/d'

sysLocation      Sitting on the Dock of the Bay
sysContact       Me <me@example.org>
sysServices      72
master agentx
agentaddress     127.0.0.1,[:1]
view systemonly  included .1.3.6.1.2.1.1
view systemonly  included .1.3.6.1.2.1.25.1
rocommunity      public default -V systemonly
rocommunity6     public default -V systemonly
rouser authPrivUser authpriv -V systemonly
```

The configuration of this service can also be changed in many ways. Therefore, we recommend setting up a VM to install and configure the SNMP server ourselves. All the settings that can be made for the SNMP daemon are defined and described in the [manpage](#).

Dangerous Settings

Some dangerous settings that the administrator can make with SNMP are:

Settings	Description
rwuser noauth	Provides access to the full OID tree without authentication.
rwcommunity <community string> <IPv4 address>	Provides access to the full OID tree regardless of where the requests were sent from.
rwcommunity6 <community string> <IPv6 address>	Same access as with rwcommunity with the difference of using IPv6.

Footprinting the Service

For footprinting SNMP, we can use tools like **snmpwalk**, **onesixtyone**, and **braa**. **Snmpwalk** is used to query the OIDs with their information. **Onesixtyone** can be used to brute-force the names of the community strings since they can be named arbitrarily by the administrator. Since these community strings can be bound to any source, identifying the existing community strings can take quite

some time.

SNMPwalk

SNMPwalk

```
dbcyp0n@htb[/htb]$ snmpwalk -v2c -c public 10.129.14.128
```

```
iso.3.6.1.2.1.1.1.0 = STRING: "Linux ht6 5.11.0-34-generic #36~20.04.1-Ubuntu SMP Fri Aug 27 08:06:32 UTC 2021 x8
iso.3.6.1.2.1.1.2.0 = OID: iso.3.6.1.4.1.8072.3.2.10
iso.3.6.1.2.1.1.3.0 = Timeticks: (5134) 0:00:51.34
iso.3.6.1.2.1.1.4.0 = STRING: "mrb3n@inlanefreight.htb"
iso.3.6.1.2.1.1.5.0 = STRING: "htb"
iso.3.6.1.2.1.1.6.0 = STRING: "Sitting on the Dock of the Bay"
iso.3.6.1.2.1.1.7.0 = INTEGER: 72
iso.3.6.1.2.1.1.8.0 = Timeticks: (0) 0:00:00.00
iso.3.6.1.2.1.1.9.1.2.1 = OID: iso.3.6.1.6.3.10.3.1.1
iso.3.6.1.2.1.1.9.1.2.2 = OID: iso.3.6.1.6.3.11.3.1.1
iso.3.6.1.2.1.1.9.1.2.3 = OID: iso.3.6.1.6.3.15.2.1.1
iso.3.6.1.2.1.1.9.1.2.4 = OID: iso.3.6.1.6.3.1
iso.3.6.1.2.1.1.9.1.2.5 = OID: iso.3.6.1.6.3.16.2.2.1
iso.3.6.1.2.1.1.9.1.2.6 = OID: iso.3.6.1.2.1.49
iso.3.6.1.2.1.1.9.1.2.7 = OID: iso.3.6.1.2.1.4
iso.3.6.1.2.1.1.9.1.2.8 = OID: iso.3.6.1.2.1.50
iso.3.6.1.2.1.1.9.1.2.9 = OID: iso.3.6.1.6.3.13.3.1.3
iso.3.6.1.2.1.1.9.1.2.10 = OID: iso.3.6.1.2.1.92
iso.3.6.1.2.1.1.9.1.3.1 = STRING: "The SNMP Management Architecture MIB."
iso.3.6.1.2.1.1.9.1.3.2 = STRING: "The MIB for Message Processing and Dispatching."
iso.3.6.1.2.1.1.9.1.3.3 = STRING: "The management information definitions for the SNMP User-based Security Model."
iso.3.6.1.2.1.1.9.1.3.4 = STRING: "The MIB module for SNMPv2 entities"
iso.3.6.1.2.1.1.9.1.3.5 = STRING: "View-based Access Control Model for SNMP."
iso.3.6.1.2.1.1.9.1.3.6 = STRING: "The MIB module for managing TCP implementations"
iso.3.6.1.2.1.1.9.1.3.7 = STRING: "The MIB module for managing IP and ICMP implementations"
iso.3.6.1.2.1.1.9.1.3.8 = STRING: "The MIB module for managing UDP implementations"
iso.3.6.1.2.1.1.9.1.3.9 = STRING: "The MIB modules for managing SNMP Notification, plus filtering."
iso.3.6.1.2.1.1.9.1.3.10 = STRING: "The MIB module for logging SNMP Notifications."
iso.3.6.1.2.1.1.9.1.4.1 = Timeticks: (0) 0:00:00.00
iso.3.6.1.2.1.1.9.1.4.2 = Timeticks: (0) 0:00:00.00
iso.3.6.1.2.1.1.9.1.4.3 = Timeticks: (0) 0:00:00.00
iso.3.6.1.2.1.1.9.1.4.4 = Timeticks: (0) 0:00:00.00
iso.3.6.1.2.1.1.9.1.4.5 = Timeticks: (0) 0:00:00.00
iso.3.6.1.2.1.1.9.1.4.6 = Timeticks: (0) 0:00:00.00
iso.3.6.1.2.1.1.9.1.4.7 = Timeticks: (0) 0:00:00.00
iso.3.6.1.2.1.1.9.1.4.8 = Timeticks: (0) 0:00:00.00
iso.3.6.1.2.1.1.9.1.4.9 = Timeticks: (0) 0:00:00.00
iso.3.6.1.2.1.1.9.1.4.10 = Timeticks: (0) 0:00:00.00
iso.3.6.1.2.1.25.1.1.0 = Timeticks: (3676678) 10:12:46.78
iso.3.6.1.2.1.25.1.2.0 = Hex-STRING: 07 E5 09 14 0E 2B 2D 00 2B 02 00
iso.3.6.1.2.1.25.1.3.0 = INTEGER: 393216
iso.3.6.1.2.1.25.1.4.0 = STRING: "BOOT_IMAGE=/boot/vmlinuz-5.11.0-34-generic root=UUID=9a6a5c52-f92a-42ea-8ddf-94
iso.3.6.1.2.1.25.1.5.0 = Gauge32: 3
iso.3.6.1.2.1.25.1.6.0 = Gauge32: 411
iso.3.6.1.2.1.25.1.7.0 = INTEGER: 0
iso.3.6.1.2.1.25.1.7.0 = No more variables left in this MIB View (It is past the end of the MIB tree)
```

...SNIP...

```
iso.3.6.1.2.1.25.6.3.1.2.1232 = STRING: "printer-driver-sag-gdi_0.1-7_all"
iso.3.6.1.2.1.25.6.3.1.2.1233 = STRING: "printer-driver-splix_2.0.0+svn315-7fakesync1build1_amd64"
iso.3.6.1.2.1.25.6.3.1.2.1234 = STRING: "procps_2:3.3.16-1ubuntu2.3_amd64"
iso.3.6.1.2.1.25.6.3.1.2.1235 = STRING: "proftpd-basic_1.3.6c-2_amd64"
iso.3.6.1.2.1.25.6.3.1.2.1236 = STRING: "proftpd-doc_1.3.6c-2_all"
iso.3.6.1.2.1.25.6.3.1.2.1237 = STRING: "psmisc_23.3-1_amd64"
iso.3.6.1.2.1.25.6.3.1.2.1238 = STRING: "publicsuffix_20200303.0012-1_all"
iso.3.6.1.2.1.25.6.3.1.2.1239 = STRING: "pulseaudio_1:13.99.1-1ubuntu3.12_amd64"
iso.3.6.1.2.1.25.6.3.1.2.1240 = STRING: "pulseaudio-module-bluetooth_1:13.99.1-1ubuntu3.12_amd64"
iso.3.6.1.2.1.25.6.3.1.2.1241 = STRING: "pulseaudio-utils_1:13.99.1-1ubuntu3.12_amd64"
iso.3.6.1.2.1.25.6.3.1.2.1242 = STRING: "python-apt-common_2.0.0ubuntu0.20.04.6_all"
iso.3.6.1.2.1.25.6.3.1.2.1243 = STRING: "python3_3.8.2-0ubuntu2_amd64"
iso.3.6.1.2.1.25.6.3.1.2.1244 = STRING: "python3-acme_1.1.0-1_all"
iso.3.6.1.2.1.25.6.3.1.2.1245 = STRING: "python3-apport_2.20.11-0ubuntu27.21_all"
iso.3.6.1.2.1.25.6.3.1.2.1246 = STRING: "python3-apt_2.0.0ubuntu0.20.04.6_amd64"
```

...SNIP...

In the case of a misconfiguration, we would get approximately the same results from `snmpwalk` as just shown above. Once we know the community string and the SNMP service that does not require authentication (versions 1, 2c), we can query internal system information like in the previous example.

Here we recognize some Python packages that have been installed on the system. If we do not know the community string, we can use `onesixtyone` and `SecLists` wordlists to identify these community strings.

OneSixtyOne

OneSixtyOne

```
dbcyph0n@htb[/htb]$ sudo apt install onesixtyone
dbcyph0n@htb[/htb]$ onesixtyone -c /opt/useful/SecLists/Discovery/SNMP/snmp.txt 10.129.14.128

Scanning 1 hosts, 3220 communities
10.129.14.128 [public] Linux htb 5.11.0-37-generic #41~20.04.2-Ubuntu SMP Fri Sep 24 09:06:38 UTC 2021 x86_64
```

Often, when certain community strings are bound to specific IP addresses, they are named with the hostname of the host, and sometimes even symbols are added to these names to make them more challenging to identify. However, if we imagine an extensive network with over 100 different servers managed using SNMP, the labels, in that case, will have some pattern to them. Therefore, we can use different rules to guess them. We can use the tool `crunch` to create custom wordlists. Creating custom wordlists is not an essential part of this module, but more details can be found in the module [Cracking Passwords With Hashcat](#).

Once we know a community string, we can use it with `braa` to brute-force the individual OIDs and enumerate the information behind them.

Braa

Braa

```
dbcyph0n@htb[/htb]$ sudo apt install braa
dbcyph0n@htb[/htb]$ braa <community string>@<IP>:.1.3.6.* # Syntax
dbcyph0n@htb[/htb]$ braa public@10.129.14.128:.1.3.6.*

10.129.14.128:20ms:.1.3.6.1.2.1.1.1.0:Linux htb 5.11.0-34-generic #36~20.04.1-Ubuntu SMP Fri Aug 27 08:06:32 UTC
10.129.14.128:20ms:.1.3.6.1.2.1.1.2.0:.1.3.6.1.4.1.8072.3.2.10
10.129.14.128:20ms:.1.3.6.1.2.1.1.3.0:548
10.129.14.128:20ms:.1.3.6.1.2.1.1.4.0:mr3n@inlanefreight.htb
10.129.14.128:20ms:.1.3.6.1.2.1.1.5.0:htb
10.129.14.128:20ms:.1.3.6.1.2.1.1.6.0:US
10.129.14.128:20ms:.1.3.6.1.2.1.1.7.0:78
...SNIP...
```

Once again, we would like to point out that the independent configuration of the SNMP service will bring us a great variety of different experiences that no tutorial can replace. Therefore, we highly recommend setting up a VM with SNMP, experimenting with it, and trying different configurations. SNMP can be a boon for an I.T. systems administrator as well as a curse for Security analysts and managers alike.

VPN Servers

 Warning: Each time you "Switch", your connection keys are regenerated and you must re-download your VPN connection file.

All VM instances associated with the old VPN Server will be terminated when switching to a new VPN server.

Existing PwnBox instances will automatically switch to the new VPN server.

us-academy-1

PROTOCOL

UDP 1337 TCP 443

DOWNLOAD VPN CONNECTION FILE

Start Instance

∞ / 1 spawns left

Waiting to start..

Questions

Answer the question(s) below to complete this Section and earn cubes!

Target: 10.129.186.116

Life Left: 74 minutes

Cheat Sheet

Download VPN Connection File

+1 Enumerate the SNMP service and obtain the email address of the admin. Submit it as the answer.

Submit your answer here...

Submit

+1 What is the customized version of the SNMP server?

Submit your answer here...

Submit

+1 Enumerate the custom script that is running on the system and submit its output as the answer.

Submit your answer here...

 Cheat Sheet
 Resources
 Go to Questions

Table of Contents

Introduction

Enumeration Principles	✓
Enumeration Methodology	✓

Infrastructure Based Enumeration

Domain Information	✓
Cloud Resources	✓
Staff	✓

Host Based Enumeration

 FTP	✓
 SMB	✓
 NFS	✓
 DNS	✓
 SMTP	✓
 IMAP / POP3	✓
 SNMP	
 MySQL	
 MSSQL	
 Oracle TNS	
 IPMI	

Remote Management Protocols

Linux Remote Management Protocols	
Windows Remote Management Protocols	

Skills Assessment

 Footprinting Lab - Easy	
 Footprinting Lab - Medium	
 Footprinting Lab - Hard	

My Workstation

OFFLINE

 Start Instance

 / 1 spawns left